API Security Risk Analysis Report

Prepared By: **Durga R**

Task 3 – API Security Analysis

Date: [09/03/2026]

1. Introduction

Modern applications rely heavily on APIs to power mobile apps, SaaS platforms, dashboards, and integrations. While APIs improve efficiency, they can also expose sensitive data if not designed securely.

This report analyzes publicly available API endpoints from JSONPlaceholder (a safe test API) to identify potential security risks. The purpose is to demonstrate how insecure API design can affect business data, and provide recommendations to reduce risk.

---

2. Tools Used

- **Browser (Google Chrome):** To send GET requests and view API responses.
- **JSONPlaceholder Public API:** Demo API for testing endpoints.
- **MS Word:** Documenting the findings in a professional report.

---

3. APIs Tested

METHOD	ENDPOINT	PURPOSE
GET	/users	Retrieve user information
GET	/posts	Retrieve posts data
GET	/comments	Retrieve comments data
GET	/albums	Retrieve album data

---

4. Testing Methodology

1. Identify publicly available API endpoints.
2. Access the endpoints using a browser.
3. Inspect the API responses for sensitive information.
4. Check if authentication is required.
5. Identify potential security risks (data exposure, open endpoints, missing controls).
6. Document findings in a business-friendly manner.

Note: Only safe, read-only GET requests were performed. No attacks, DoS, or data modification were attempted.

---

5. Security Findings

5.1 `/users` Endpoint

Observation:
The `/users` endpoint provides detailed user information, including name, username, email, phone, address, and company details, without requiring authentication.

Risk:

- Open API Endpoint
- Excessive Data Exposure

Business Impact:

- Personal data could be accessed by unauthorized parties.
- Potential misuse of sensitive customer information.

Recommendation:

- Implement authentication (API keys, OAuth tokens).
- Limit returned fields to only necessary data.

Screenshot: Figure1: users_api.png

5.2 `/posts` Endpoint

Observation:

The `/posts` endpoint exposes all posts publicly with no login required. Each post includes userId, post id, title, and body.

Risk:

- Open API Endpoint

Business Impact:

- Anyone can view internal posts, potentially revealing business content.

Recommendation:

- Apply authentication if post data is sensitive.
- Consider access control for production APIs.

Screenshot: Figure2: posts_api.png

5.3 `/comments` Endpoint

Observation:

The /comments endpoint exposes comment data including user email addresses.

Risk:

- Sensitive Information Exposure

Business Impact:

- Email addresses can be used for spam or phishing campaigns.

Recommendation:

- Mask email addresses in responses.
- Implement authentication if email visibility is unnecessary.

Screenshot: Figure3: comments_api.png

5.4 `/albums` Endpoint (Optional / Screenshot 4)

Observation:
The `/albums` endpoint is publicly accessible without authentication.

Risk:

- Open API Endpoint

Business Impact:

- Unauthorized access to business-related album data.

Recommendation:

- Apply authentication or restrict data access based on user roles.

Screenshot: Figure4: albums_api.png

---

6. Risk Severity and Business Impact

VULNERABILITY/END POINT	RISK LEVEL	BUSINESS IMPACT	RECOMMENDATION
/users – Open endpoint	**Medium**	**Attackers can access sensitive user data**	**Implement authentication and limit data exposure**
/users – Excessive data exposure	**Medium**	**Privacy violation, data misuse**	**Only return necessary fields**
/comments – Exposed emails	**Low**	**Emails could be collected for spam/phishing**	**Mask or restrict email fields**
/posts – No rate limiting	**Low**	**Unlimited requests could overload the system**	**Implement request rate limiting**
/albums – Open endpoint	**Low**	**Public access without control**	**Apply authentication if needed**

---

7. Conclusion

The API security analysis identified several potential risks including:

- Open endpoints without authentication
- Excessive data exposure
- Email information visible publicly
- Lack of rate limiting

Business Impact: Sensitive information exposure may lead to privacy concerns, potential misuse, and reputational risks.

Recommendation: Implement proper authentication, access control, rate limiting, and limit sensitive data exposure to reduce the risk to business systems.

---

7. Screenshots

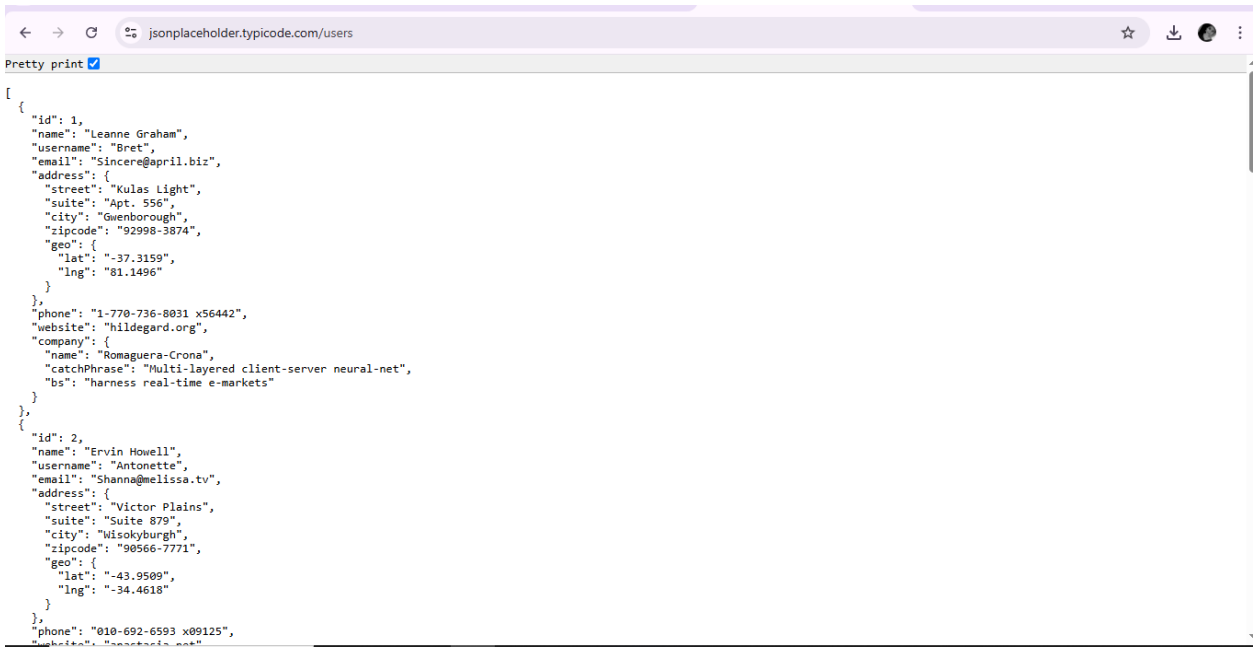
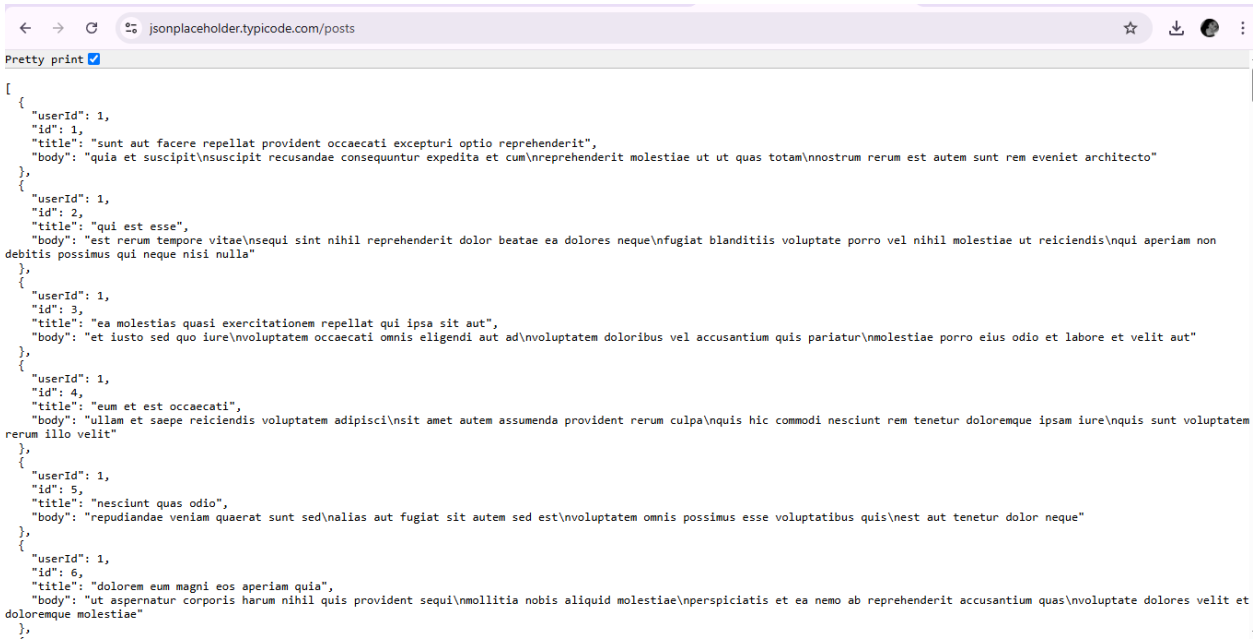
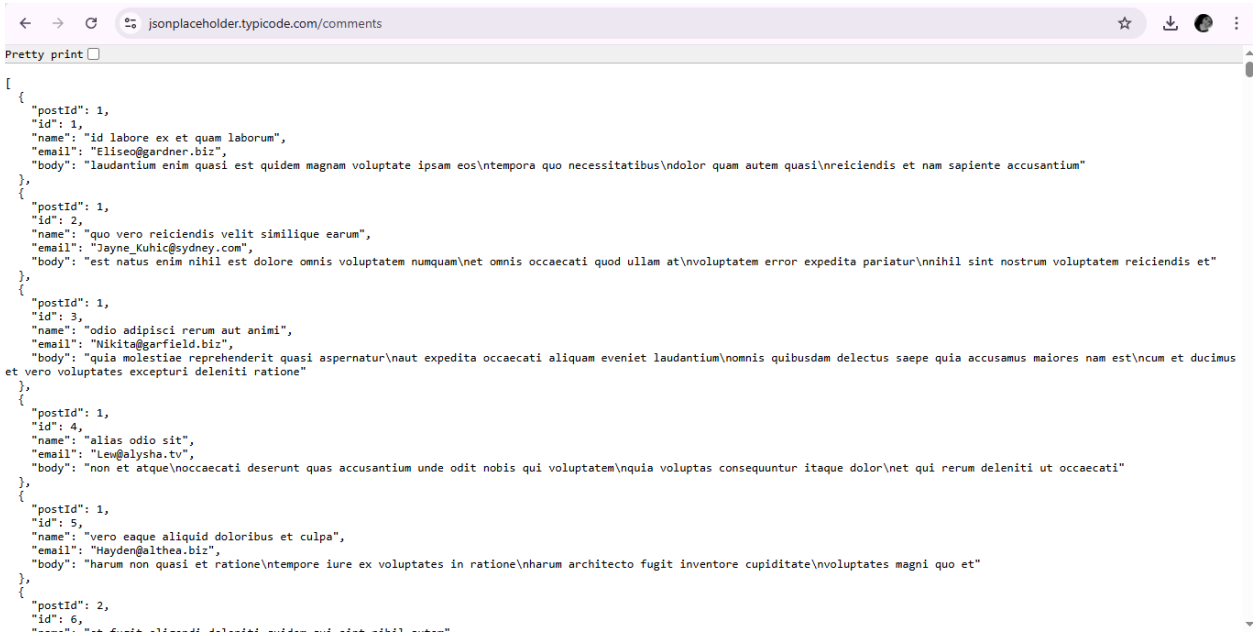


Figure 1: `/users` API response showing user data including email and phone.




```
[
  {
    "userId": 1,
    "id": 1,
    "title": "sunt aut facere repellat provident occaecati excepturi optio reprehenderit",
    "body": "quia et suscipit\nsuscipit recusandae consequuntur expedita et cum\nreprehenderit molestiae ut ut quas totam\nnostrum rerum est autem sunt rem eveniet architecto"
  },
  {
    "userId": 1,
    "id": 2,
    "title": "qui est esse",
    "body": "est rerum tempore vitae\nsequi sint nihil reprehenderit dolor beatae ea dolores neque\nfugiat blanditiis voluptate porro vel nihil molestiae ut reiciendis\nqui aperiam non
debitis possimus qui neque nisi nulla"
  },
  {
    "userId": 1,
    "id": 3,
    "title": "ea molestias quasi exercitationem repellat qui ipsa sit aut",
    "body": "et iusto sed quo iure\nvoluptatem occaecati omnis eligendi aut ad\nvoluptatem doloribus vel accusantium quis pariatur\nmolestiae porro eius odio et labore et velit aut"
  },
  {
    "userId": 1,
    "id": 4,
    "title": "eum et est occaecati",
    "body": "ullam et saepe reiciendis voluptatem adipisci\nsit amet autem assumenda provident rerum culpa\nquis hic commodi nesciunt rem tenetur doloremque ipsam iure\nquis sunt voluptatem
rerum illo velit"
  },
  {
    "userId": 1,
    "id": 5,
    "title": "nesciunt quas odio",
    "body": "repudiandae veniam quaerat sunt sed\nalias aut fugiat sit autem sed est\nvoluptatem omnis possimus esse voluptatibus quis\nest aut tenetur dolor neque"
  },
  {
    "userId": 1,
    "id": 6,
    "title": "dolorem eum magni eos aperiam quia",
    "body": "ut aspernatur corporis harum nihil quis provident sequi\nmollitia nobis aliquid molestiae\nperspiciatis et ea nemo ab reprehenderit accusantium quas\nvoluptate dolores velit et
doloremque molestiae"
  },
```


Figure 2: `/posts` API response showing publicly accessible posts.




```
[
  {
    "postId": 1,
    "id": 1,
    "name": "id labore ex et quam laborum",
    "email": "Eliseo@gardner.biz",
    "body": "laudantium enim quasi est quidem magnam voluptate ipsam eos\ntempora quo necessitatibus\ndolor quam autem quasi\nreiciendis et nam sapiente accusantium"
  },
  {
    "postId": 1,
    "id": 2,
    "name": "quo vero reiciendis velit similique earum",
    "email": "Jayne_Kuhic@sydney.com",
    "body": "est natus enim nihil est dolore omnis voluptatem numquam\net omnis occaecati quod ullam at\nvoluptatem error expedita pariatur\nnihil sint nostrum voluptatem reiciendis et"
  },
  {
    "postId": 1,
    "id": 3,
    "name": "odio adipisci rerum aut animi",
    "email": "Nikita@garfield.biz",
    "body": "quia molestiae reprehenderit quasi aspernatur\naut expedita occaecati aliquam eveniet laudantium\nomnis quibusdam delectus saepe quia accusamus maiores nam est\ncum et ducimus
et vero voluptates excepturi deleniti ratione"
  },
  {
    "postId": 1,
    "id": 4,
    "name": "alias odio sit",
    "email": "Lew@alysha.tv",
    "body": "non et atque\noccaecati deserunt quas accusantium unde odit nobis qui voluptatem\nquia voluptas consequuntur itaque dolor\net qui rerum deleniti ut occaecati"
  },
  {
    "postId": 1,
    "id": 5,
    "name": "vero eaque aliquid doloribus et culpa",
    "email": "Hayden@althea.biz",
    "body": "harum non quasi et ratione\ntempore iure ex voluptates in ratione\nharum architecto fugit inventore cupiditate\nvoluptates magni quo et"
  },
  {
    "postId": 2,
    "id": 6,
```


Figure 3: `/comments` API response showing exposed email addresses.

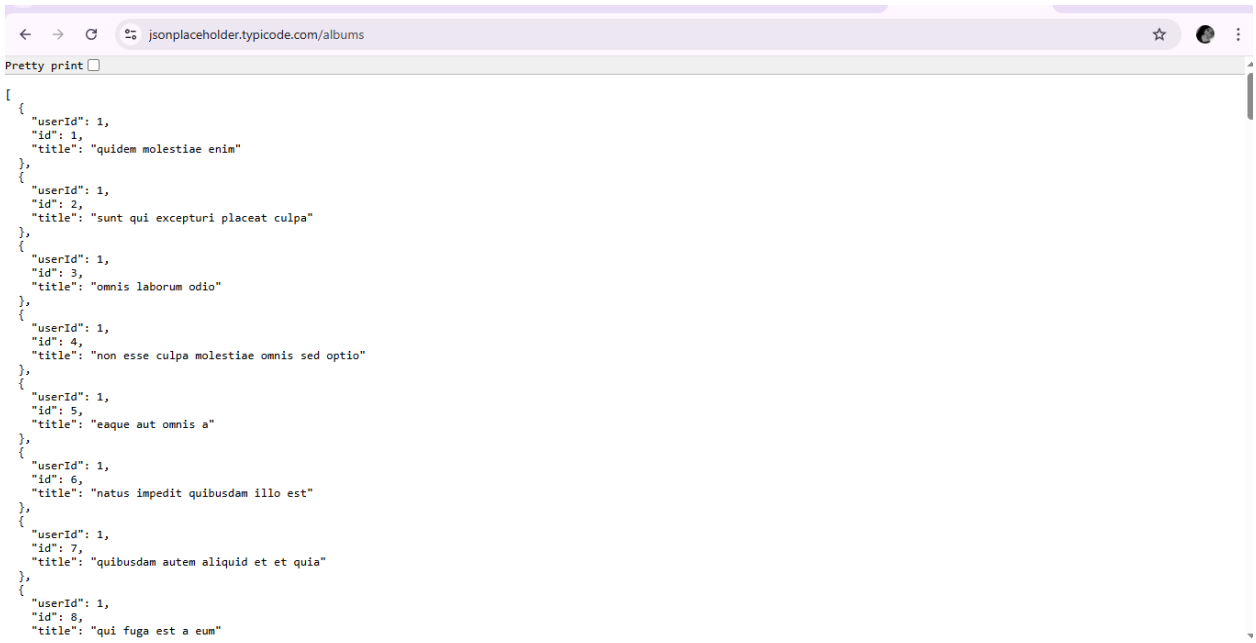


Figure 4: `/albums` API response showing public access (optional).

---

9. Appendix / References

- JSONPlaceholder API Documentation: https://jsonplaceholder.typicode.com
- OWASP API Security Top 10: https://github.com/OWASP/API-Security